



Tswap Protocol Audit Report

Version 1.0

Cyfrin.io

October 5, 2026

t-swap Audit Report

Ali Talal

October 5, 2026

Prepared by: Ali Talal Lead Auditors: - Ali Talal

Table of Contents

- Table of Contents
- Protocol Summary
- Disclaimer
- Risk Classification
- Audit Details
 - Scope
 - Roles
- Executive Summary
 - Issues found
- Findings
 - High
 - Medium
 - Low
 - Informational
 - Gas

Protocol Summary

Protocol does X, Y, Z

Disclaimer

The YOUR_NAME_HERE team makes all effort to find as many vulnerabilities in the code in the given time period, but holds no responsibilities for the findings provided in this document. A security audit by the team is not an endorsement of the underlying business or product. The audit was time-boxed and the review of the code was solely on the security aspects of the Solidity implementation of the contracts.

Risk Classification

		Impact		
		High	Medium	Low
Likelihood	High	H	H/M	M
	Medium	H/M	M	M/L
	Low	M	M/L	L

We use the CodeHawks severity matrix to determine severity. See the documentation for more details.

Audit Details

The security review of T-Swap was conducted by Ali Talal. The review focused on the Solidity implementations of the pool factory and constant-product AMM pool contracts, with particular attention to the $x * y = k$ invariant, fee accounting, slippage/deadline protections, and liquidity provider flows.

Scope

The audit scope covered the following contracts:

File	Description
<code>src/PoolFactory.sol</code>	Deploys and tracks ERC20/WETH pool instances
<code>src/TSwapPool.sol</code>	Constant-product AMM pool for swaps and liquidity

Out of scope: deployment scripts, tests, mocks, and third-party dependencies under `lib/` (including OpenZeppelin and forge-std).

Compilation target: Solidity 0.8.20 (per `foundry.toml`).

Roles

Role	Description
Liquidity Provider (LP)	Deposits WETH and pool tokens into a <code>TSwapPool</code> , receives LP tokens representing their share of the pool, and may later withdraw liquidity.
Swapper / User	Permissionlessly swaps between an ERC20 pool token and WETH via <code>swapExactInput</code> , <code>swapExactOutput</code> , or helper flows such as <code>sellPoolTokens</code> .
Pool Factory Deployer / Caller	Any address may call <code>PoolFactory::createPool</code> to deploy a new ERC20/WETH pool for a given token.

There is no privileged admin or owner role in the in-scope contracts; the protocol is designed to operate permissionlessly once deployed.

Executive Summary

This review assessed T-Swap, a Uniswap-V1-style automated market maker that pairs any ERC20 with WETH. The engagement identified several high-severity issues that can break core protocol guarantees or cause direct user/protocol loss, including an unused deposit deadline, incorrect fee scaling

in exact-output swaps, missing slippage protection on `swapExactOutput`, incorrect routing in `sellPoolTokens`, and an incentive mechanism in `_swap` that breaks the $x * y = k$ invariant.

Medium- and low-severity findings further highlight token compatibility risks and incorrect event/return-value reporting. Informational items cover missing zero-address checks, unused errors, and event indexing improvements.

Overall, the protocol should not be considered production-ready until the high-severity findings—especially those affecting the constant-product invariant and swap fee/slippage protections—are remediated and re-tested.

Issues found

Severity	Number of issues found
High	4
Medium	2
Low	2
Info	9
Total	17

Findings

High

[H-1] `TSwapPool::deposit` is missing deadline check causing transactions to complete even after the deadline

Description: The `deposit` function accepts a deadline parameter, which according to the documentation is “The deadline for the transaction to be completed by”. However, this parameter is never used. As a consequence, operations that add liquidity to the pool might be executed at unexpected times, in market conditions where the deposit rate is unfavorable.

Impact: Transactions could be sent when market conditions are unfavorable to deposit, even when adding a deadline parameter.

Proof of Concept: The `deadline` parameter is unused.

Recommended Mitigation: Consider making the following change to the function.

```
1 function deposit(  
2     uint256 wethToDeposit,  
3     uint256 minimumLiquidityTokensToMint, // LP tokens -> if empty, we  
        can pick 100% (100% == 17 tokens)  
4     uint256 maximumPoolTokensToDeposit,  
5     uint64 deadline  
6 )  
7     external  
8 +     revertIfDeadlinePassed(deadline)  
9     revertIfZero(wethToDeposit)  
10    returns (uint256 liquidityTokensToMint)
```

[H-2] Incorrect fee calculation in `TSwapPool::getInputAmountBasedOnOutput` causes protocol to take too many tokens from users, resulting in lost fees

Description: The `getInputAmountBasedOnOutput` function is intended to calculate the amount of tokens a user should deposit given an amount of tokens of output tokens. However, the function currently miscalculates the resulting amount. When calculating the fee, it scales the amount by 10_000 instead of 1_000.

Impact: Protocol takes more fees than expected from users.

```
1 function getInputAmountBasedOnOutput(  
2     uint256 outputAmount,  
3     uint256 inputReserves,  
4     uint256 outputReserves  
5 )  
6     public  
7     pure  
8     revertIfZero(outputAmount)  
9     revertIfZero(outputReserves)  
10    returns (uint256 inputAmount)  
11    {  
12  
13 -        return  
14            ((inputReserves * outputAmount) * 10000) /  
15            ((outputReserves - outputAmount) * 997);  
16 +        return  
17            ((inputReserves * outputAmount) * 1000) /  
18            ((outputReserves - outputAmount) * 997);  
19    }
```

[H-3] Lack of slippage protection in TSwapPool::swapExactOutput causes users to potentially receive way fewer tokens

Description: The `swapExactOutput` function does not include any sort of slippage protection. This function is similar to what is done in `TSwapPool::swapExactInput`, where the function specifies a `minOutputAmount`, the `swapExactOutput` function should specify a `maxInputAmount`.

Impact: If market conditions change before the transaction processes, the user could get a much worse swap.

Impact: If market conditions change before the transaction processes, the user could get a much worse swap.

Proof of Concept: 1. The price of 1 WETH right now is 1,000 USDC 2. User inputs a `swapExactOutput` looking for 1 WETH 1. inputToken = USDC 2. outputToken = WETH 3. outputAmount = 1 4. deadline = whatever 3. The function does not offer a maxInput amount 4. As the transaction is pending in the mempool, the market changes! And the price moves HUGE -> 1 WETH is now 10,000 USDC. 10x more than the user expected 5. The transaction completes, but the user sent the protocol 10,000 USDC instead of the expected 1,000 USDC

Recommended Mitigation: We should include a `maxInputAmount` so the user only has to spend up to a specific amount, and can predict how much they will spend on the protocol.

```
1 function swapExactOutput
2     IERC20 inputToken,
3 +   uint256 maxInputAmount,
4   .
5   .
6   .
7       inputAmount = getInputAmountBasedOnOutput(outputAmount,
8           inputReserves, outputReserves);
9 +   if(inputAmount > maxInputAmount){
10 +       revert();
11   }
12   _swap(inputToken, inputAmount, outputToken, outputAmount);
```

[H-4] TSwapPool::sellPoolTokens mismatches input and output tokens causing users to receive the incorrect amount of tokens

Description: The `sellPoolTokens` function is intended to allow users to easily sell pool tokens and receive WETH in exchange. Users indicate how many pool tokens they're willing to sell in

the `poolTokenAmount` parameter. However, the function currently miscalculates the swapped amount.

This is due to the fact that the `swapExactOutput` function is called, whereas the `swapExactInput` function is the one that should be called. Because users specify the exact amount of input tokens, not output.

Impact: Users will swap the wrong amount of tokens, which is a severe disruption of protocol functionality.

Proof of Concept:

Recommended Mitigation:

Consider changing the implementation to use `swapExactInput` instead of `swapExactOutput`. Note that this would also require changing the `sellPoolTokens` function to accept a new parameter (ie `minWethToReceive` to be passed to `swapExactInput`)

```
function sellPoolTokens( uint256 poolTokenAmount, + uint256 minWethToReceive, ) external returns
(uint256 wethAmount) { - return swapExactOutput(i_poolToken, i_wethToken, poolTokenAmount,
uint64(block.timestamp)); + return swapExactInput(i_poolToken, poolTokenAmount, i_wethToken,
minWethToReceive, uint64(block.timestamp)); }
```

Additionally, it might be wise to add a deadline to the function, as there is currently no deadline. (MEV Later)

[H-5] In `TSwapPool : : _swap` the extra tokens given to users after every `swapCount` breaks the protocol invariant of $x * y = k$

Description: The protocol follows a strict invariant of $x * y = k$. Where: - x : The balance of the pool token - y : The balance of WETH - k : The constant product of the two balances

This means, that whenever the balances change in the protocol, the ratio between the two amounts should remain constant, hence the k . However, this is broken due to the extra incentive in the `_swap` function. Meaning that over time the protocol funds will be drained

The follow block of code is responsible for the issue

```
1     swap_count++;
2     if (swap_count >= SWAP_COUNT_MAX) {
3         swap_count = 0;
4         outputToken.safeTransfer(msg.sender, 1_000_000_000_000_000_000)
5         };
6     }
```

Impact: A user could maliciously drain the protocol of funds by doing a lot of swaps and collecting the extra incentive given out by the protocol.

Most simply put, the protocol's core invariant is broken.

Proof of Concept: 1. A user swaps 10 times, and collects the extra incentive of 1_000_000_000_000_000_000 tokens 2. That user continues to swap untill all the protocol funds are drained

Proof Of Code

Place the following into `TSwapPool.t.sol`.

```
1 function testInvariantBroken() public {
2     vm.startPrank(LiquidityProvider);
3     weth.approve(address(pool), 100e18);
4     poolToken.approve(address(pool), 100e18);
5     pool.deposit(100e18, 100e18, 100e18, uint64(block.timestamp));
6     vm.stopPrank();
7
8     uint256 outputWeth = 1e17;
9
10
11     vm.startPrank(user);
12     poolToken.approve(address(pool), type(uint256).max);
13     poolToken.mint(user, 100e18);
14     pool.swapExactOutput(poolToken, weth, outputWeth, uint64(block.timestamp));
15     pool.swapExactOutput(poolToken, weth, outputWeth, uint64(block.timestamp));
16     pool.swapExactOutput(poolToken, weth, outputWeth, uint64(block.timestamp));
17     pool.swapExactOutput(poolToken, weth, outputWeth, uint64(block.timestamp));
18     pool.swapExactOutput(poolToken, weth, outputWeth, uint64(block.timestamp));
19     pool.swapExactOutput(poolToken, weth, outputWeth, uint64(block.timestamp));
20     pool.swapExactOutput(poolToken, weth, outputWeth, uint64(block.timestamp));
21     pool.swapExactOutput(poolToken, weth, outputWeth, uint64(block.timestamp));
22     pool.swapExactOutput(poolToken, weth, outputWeth, uint64(block.timestamp));
23
24     int256 startingY = int256(weth.balanceOf(address(pool)));
25     int256 expectedDeltaY = int256(-1) * int256(outputWeth);
26 }
```

```
27     pool.swapExactOutput(poolToken, weth, outputWeth, uint64(block.  
    timestamp));  
28  
29     vm.stopPrank();  
30  
31     uint256 endingY = weth.balanceOf(address(pool));  
32     int256 actualDeltaY = int256(endingY) - int256(startingY);  
33     assertEq(actualDeltaY, expectedDeltaY);  
34 }
```

Recommended Mitigation: Remove the extra incentive mechanism. If you want to keep this in, we should account for the change in the $x * y = k$ protocol invariant. Or, we should set aside tokens in the same way we do with fees.

```
1 - swap_count++;  
2 - // Fee-on-transfer  
3 - if (swap_count >= SWAP_COUNT_MAX) {  
4 -     swap_count = 0;  
5 -     outputToken.safeTransfer(msg.sender, 1_000_000_000_000_000_000)  
6 -     ;  
7 - }
```

[M-2] Rebase, fee-on-transfer, and ERC-777 tokens break protocol invariant

/// finding....

Low

[L-1] TSwapPool::LiquidityAdded event has parameters out of order

Description: When the `LiquidityAdded` event is emitted in the `TSwapPool::_addLiquidityMintAndTransfer` function, it logs values in an incorrect order. The `poolTokensToDeposit` value should go in the third parameter position, whereas the `wethToDeposit` value should go second.

Impact: Event emission is incorrect, leading to off-chain functions potentially malfunctioning.

Recommended Mitigation:

```
1 - emit LiquidityAdded(msg.sender, poolTokensToDeposit, wethToDeposit);  
2 + emit LiquidityAdded(msg.sender, wethToDeposit, poolTokensToDeposit);
```

[L-2] Default value returned by TSwapPool : : swapExactInput results in incorrect return value given

Description: The `swapExactInput` function is expected to return the actual amount of tokens bought by the caller. However, while it declares the named return value `output` it is never assigned a value, nor uses an explicit return statement.

Impact: The return value will always be 0, giving incorrect information to the caller.

```
1
2     uint256 inputReserves = inputToken.balanceOf(address(this));
3     uint256 outputReserves = outputToken.balanceOf(address(this));
4
5 -     uint256 outputAmount = getOutputAmountBasedOnInput(inputAmount,
6 +     inputReserves, outputReserves);
7     output = getOutputAmountBasedOnInput(inputAmount, inputReserves
8     , outputReserves);
9
10 -     if (output < minOutputAmount) {
11 -         revert TSwapPool__OutputTooLow(outputAmount,
12 +         minOutputAmount);
13 +     if (output < minOutputAmount) {
14 +         revert TSwapPool__OutputTooLow(output, minOutputAmount);
15 +     }
16
17 -     _swap(inputToken, inputAmount, outputToken, outputAmount);
18 +     _swap(inputToken, inputAmount, outputToken, output);
19 }
```

Informationals**[I-1] PoolFactory::PoolFactory__PoolDoesNotExist is not used and should be removed**

```
1 - error PoolFactory__PoolDoesNotExist(address tokenAddress);
```

[I-2] Lacking zero address checks

```
1     constructor(address wethToken) {
2 +     if(wethToken == address(0)) {
3 +         revert();
4 +     }
5     i_wethToken = wethToken;
```

```
6      }
```

[I-3] PoolFactory::createPool should use .symbol() instead of .name()

```
1 -      string memory liquidityTokenSymbol = string.concat("ts", IERC20
    (tokenAddress).name());
2 +      string memory liquidityTokenSymbol = string.concat("ts", IERC20
    (tokenAddress).symbol());
```

[I-4]: Event is missing indexed fields

Index event fields make the field more quickly accessible to off-chain tools that parse events. However, note that each index field costs extra gas during emission, so it's not necessarily best to index the maximum allowed per event (three fields). Each event should use three indexed fields if there are three or more fields, and gas usage is not particularly of concern for the events in question. If there are fewer than three fields, all of the fields should be indexed.

- Found in src/TSwapPool.sol: Line: 44
- Found in src/PoolFactory.sol: Line: 37
- Found in src/TSwapPool.sol: Line: 46
- Found in src/TSwapPool.sol: Line: 43